TAYLOR'S UNIVERSITY

TECHNICAL REPORT

RiskPilot AI SOC Triage

Technical report for Agentic Cyber Defence

A historical flow investigation prototype with evidence checks and analyst control.

Prepared by

Wong Li En
Tian Xinyu
Wong Chin Wen

Competition

HackAI 2026
GDEX x ANON x UTAR Agentic AI Cybersecurity Hackathon

Report date

24 October 2026

Project conclusion

RiskPilot AI provides a working investigation workflow for PortScan, DoS and suspected BruteForce. Software and evidence checks pass, but external testing shows weak detector generalisation; a small external AI diagnostic deferred all five judgments. The prototype supports analyst investigation; it does not establish reliable autonomous attack detection or response.

Project Overview

RiskPilot AI is the project name used in this report. The implementation is maintained in the SOC-Triage repository and displayed as SOC Desk. It turns historical network-flow records into rule alerts, groups them into cases and lets an analyst inspect evidence before requesting an AI assessment. The AI can select four read-only tools. The backend checks the resulting proposal, and a human records the decision.

The current bundle contains 9 cases, 158 alerts and 948 sampled flows, represented by 1,106 traceable timeline events. The displayed attack scope is PortScan, DoS and BruteForce. Benign is an offline evaluation label, not an attack rule and not an automatic safe conclusion. DDoS compatibility remains in defensive tests but is outside the current demonstration queue.

The strongest demonstrated result is a controlled, auditable workflow. The latest automated regression suite and all 21 synthetic safety scenarios passed. However, the current rules missed 73 attack-labelled minute groups in development data and generalised poorly to a separate source. In a five-case external AI diagnostic, every verdict was Needs Review. These are different measurements and must not be combined into an accuracy score.

1 Problem and User

1 1 Analyst workload

SOC analysts must decide whether an alert needs investigation and which records support that decision. Alahmadi et al. (2022) found that perceived false positives often involved legitimate activity triggering a real alarm. Their work also describes the burden of manual validation. This motivates evidence organisation and clear uncertainty rather than automatic dismissal [2].

1 2 Intended user and task

The intended users are Tier 1 and Tier 2 analysts reviewing a suspected incident. They need to understand what triggered a case, see its timing, inspect supporting records, assess the AI explanation and record their own decisions. The prototype replays historical data; it is not a production sensor, live network monitor or endpoint response platform.

1 3 Competition fit

The Agentic Cyber Defence brief asks for a working end-to-end defensive agent, visible tool choices and evidence, human approval before consequential actions, an activity record and limitations. Its SOC triage direction specifically includes alert grouping, incident timelines and next investigation steps [1]. This report follows the six requested demonstration areas and distinguishes implemented behaviour from unproven operational value.

2 Inputs and Evidence

2 1 Data and scoring boundaries

Development uses the CIC-IDS2017 GeneratedLabelledFlows archive, specifically the Monday, Tuesday, Wednesday and Friday afternoon PortScan CSVs. The official dataset contains labelled network flows derived from captured traffic [3]. Labels are retained for offline evaluation and withheld from the model-facing tool schemas. They do not determine which rule fires or how alerts are grouped.

Each detection unit is an ordered source IP, destination IP and calendar minute within one source file. A CSV row counts as one flow record. Forward and backward packet counts are summed. Source-file boundaries and communication direction remain separate. The data clock is displayed as dataset time because the original timestamps do not independently establish UTC.

2 2 Prototype detection rules

Rule	Current trigger
PortScan	At least 100 flows and 100 destination ports, plus either source ports at least twice destination ports, or at least 250 destination ports and 2 source ports.
DoS	At least 1,000 flows and 10,000 packets, at most 10 destination ports and at least 10 source ports.
BruteForce	At least 50 connections from one source to one target FTP port 21 or SSH port 22 during one minute.

These are development heuristics, not thresholds established by the cited literature. First-match rule priority applies. A rule hit indicates traffic that warrants review. FTP or SSH connections do not demonstrate failed credentials, and high traffic volume does not demonstrate an outage. No rule match must not be interpreted as Benign.

2 3 Grouping and evidence retention

A case joins consecutive alerts only when source file, rule type and ordered source and destination match, with no more than five minutes between alert-minute starts. BruteForce also requires the same target login port. Different sources or destinations are not merged merely because they share a target or scanner. Related cases may be linked without becoming one case.

The exported bundle retains up to six flow samples per alert, with source file and CSV row pointers. An optional local indexed database supports paginated inspection of the original flow records. The AI receives bounded samples and aggregates, not the entire raw archive. Labels, source filenames and analyst-only annotations are excluded from its tool view.

3 Agent Workflow

3 1 Case navigation

The case workspace has four tabs: Overview, Timeline, Recommendations and Case record. Overview combines the rule summary, explainable review priority and AI investigation. Timeline opens minute-level alerts and linked communication records. Recommendations separates proposed steps from analyst choices. Case record presents a printable report with evidence appendices. Each tab states its task in one sentence; actions use consistent placement and labels.

3 2 Read only investigation tools

Tool	Evidence supplied
get_incident_details	Addresses, complete grouped-case start and end, rule-bucket size, case flow total and sample size.
get_related_alerts	Linked alert IDs and per-minute rule measurements; offset supports continuation.
get_network_flows	A bounded selection of sampled flow records with citable IDs.
get_incident_statistics	Case totals and explicitly separated sample-derived statistics.

The live model chooses tools through the backend allowlist. Every call is scoped to the active case. Unknown tools, invalid arguments and cross-case reads are rejected. The loop has configured limits of six model steps and twelve tool calls. A missing or failing live provider produces an unavailable or error state, rather than silently switching to a mock verdict.

3 3 Validation and disclosure limits

A proposal may say Likely Attack, Likely Benign or Needs Review. It must satisfy the output schema and evidence rules. The backend checks cited IDs against the active case and evidence actually returned to the model. Numeric claims must be supported by retrieved and canonical measurements. This does not prove the interpretation, causal claim or confidence is correct.

Each tool message retains the 8,000-character disclosure limit. Large arrays are reduced as complete JSON with an explicit omitted-record marker; alert pages can be continued. Omitted records do not enter the seen-evidence set. An oversized single record returns an error rather than broken JSON. Tool and validation outcomes are audited.

3 4 Timeline and ATT&CK

Timeline reconstruction is deterministic. All 1,106 current events resolve to case evidence and their stored order can be reproduced. PortScan may receive a tentative T1046 Network Service Discovery hint. Current DoS and BruteForce records remain Unmapped when flows cannot establish availability loss or credential guessing. MITRE defines those stronger behaviours in T1498 and T1110 [5-7]. The backend checks mapping compatibility and retrieved citations; a supported hint is not a confirmed attack.

4 Defensive Action

4 1 Investigation support

The agent proposes investigation actions such as reviewing related flows, checking alerts, reviewing the timeline or escalating to an analyst. Suggestions are linked to evidence. The intended defensive output is an explainable assessment and investigation plan; the AI does not block addresses, isolate devices, modify evidence, downgrade severity or close a case.

This restriction is structural: the AI tool registry exposes reads only. It aligns with OWASP guidance to limit functionality and authority and retain human control over consequential actions [8]. It reduces the range of possible effects but does not establish immunity to prompt injection or incorrect reasoning.

4 2 Safe closure and manual resolution

A Likely Benign proposal on PortScan, DoS or BruteForce requires explicit analyst confirmation before it can be treated as benign. Legacy DDoS is protected as well. Confirming such a proposal requires a written reason; rejecting an AI assessment also requires a reason. Neither AI confirmation nor recommendation approval automatically closes or downgrades the case.

The product supports a separate manual Resolve Case action after a case record has been saved. It requires the signed-in analyst, a reason of 10 to 1,000 characters and an exact true confirmation. The resolution is recorded in the audit trail. This human operation must not be described as autonomous AI remediation.

5 Human Approval

5 1 Review decisions and case notes

The analyst may select a subset of the proposed investigation steps. Approve means accepting a step into the investigation work list, not accepting the AI verdict or authorising a network change. Save decisions records the selected approvals and rejections. Approved steps appear in Home for the analyst to carry out and mark done. A case-note draft is created only when a step is approved; completion remains a separate record.

Confirm assessment in Overview accepts the proposed evidence interpretation. Approve in Recommendations accepts a future investigation step. Save summary to audit log preserves the record even if optional steps remain unreviewed; it does not resolve the case. Resolve Case is a separate explicit analyst decision. The printable report distinguishes its saved summary from current supporting evidence. No approval is required merely to inspect read-only evidence [1].

5 2 Identity and audit

The local API uses a signed-in session and CSRF checks for writes. Recommendation approvals, notes, task completion, AI decisions and record operations bind the reviewer to the signed-in user. AI runs, tool calls, rejected outputs, analyst decisions, notes and resolution events enter a shared SQLite audit table with a hash chain. Update and delete triggers enforce append-only behaviour through normal database access. Individual recommendation decisions and their audit entries are transaction-linked; the whole workflow is not claimed to be one atomic transaction.

6 Results and Limitations

6 1 Historical development detection

The complete selected CIC-IDS2017 files were rescored, including groups that produced no alerts. Of 356,103 groups, 11 out-of-scope attack groups were excluded. The remaining in-scope attack total was 229 groups. The detector produced 156 true positives, 2 false positives from Benign and 73 false negatives. Binary precision was 98.73% and recall was 68.12%.

Rule	TP	FP	FN	Precision	Recall
PortScan	11	1	16	91.67%	40.74%
DoS	23	1	52	95.83%	30.67%
BruteForce	122	0	5	100.00%	96.06%

Of 355,863 Benign groups, 2 triggered rules: a false-positive rate of approximately 0.000562%, not zero. The exported nine cases include two cases whose grouped ground truth is purely Benign. Case grouping reconstruction passed, but evaluation of alert-bearing cases alone cannot establish case-level recall. These data informed development, so the numbers are not independent performance results.

6 2 External domain detection

CIDDS-001 OpenStack internal weeks 1 to 4 were evaluated separately [4]. The detector, adapter and archive hashes were frozen before scoring, and the acceptance rerun reproduced the stored external result. One unidirectional NetFlow row counts as one flow; the scoring unit remains source file, ordered address pair and minute. Ambiguous or out-of-scope groups are excluded; a Benign and single-target-attack mixture is scored as attack.

Rule	TP	FP	FN	Recall
PortScan	48	0	40,617	0.118%
DoS	56	0	80	41.176%
BruteForce	2	0	555	0.359%

The external test scored 5,942,316 groups and excluded 4,260 ambiguous or out-of-scope groups; 786 scored groups mixed Benign with one attack type. Recall is poor, especially for PortScan and BruteForce. Zero observed false positives alongside few positive predictions is not evidence of broadly reliable precision. The thresholds were not retuned against this frozen test.

6 3 Real AI investigations

Historical measurements below come from two earlier sets run with the real Codex provider, before the grouped-window correction. They retain their original prompt hashes and must not be represented as a rerun of the final implementation. Each run used isolated state and audit files and left analyst decisions pending. No production decision was approved for the user. Both sets used the configured default model, temperature setting 0.0, six-step limit and twelve-tool limit. The default model alias does not pin an underlying version or guarantee deterministic answers.

Measure	Development smoke	External diagnostic
Cases and runs	5 cases and 5 runs	5 groups and 5 runs
Completed investigations	5 of 5	5 of 5
Likely Attack	2	0
Needs Review	3	5
Likely Benign	0	0
Original validator failures	0	0
Audit chains verified	5 of 5	5 of 5
Median tool calls	4	4
Median run time	42.69 seconds	39.39 seconds

The development smoke cases had already been inspected and test workflow behaviour only. The external diagnostic selected one group for each target attack and two normal groups from CIDDS week 1 by a fixed CSV-order rule, before model calls. Original labels were excluded from model inputs. Unmatched groups entered an isolated review queue; they were not counted as successful detector alerts.

All five external verdicts were Needs Review. Attack-to-Likely-Benign was 0/3 and Benign-to-Likely-Attack was 0/2, but abstention was 5/5. This is not 100% accuracy: the agent made no definite classification. Subsequent discovery of unsupported time-window statements also shows why passing identifier and numeric checks is not proof of a correct explanation. There were only five purposively selected groups, with dataset labels and automated consistency checks rather than human expert adjudication. They share the CIDDS source with the detector test and cannot establish generalisable AI accuracy.

6 4 Software and safety verification

The latest full regression suite passed 280 tests with zero failures or skips, and the frontend production build passed. The machine-readable test count is recorded in data/final-workflow-tests.xml. The suite covers rule and grouping boundaries, label withholding, tool scope, numeric and citation checks, bounded JSON continuation, safety denial, forged reviewer identities, manual resolution and append-only auditing. A separate synthetic safety contract evaluation passed 21/21 scenarios. These counts measure software contracts, not a 100% safety rate or analyst effectiveness.

6 5 Remaining limitations

Detector coverage is the main weakness. Many externally labelled attacks never trigger a rule and therefore never reach the normal AI workflow. Fixed minute boundaries can split bursts, count thresholds miss slow activity and first-match rule priority can mask simultaneous behaviours. Address-and-time grouping is practical correlation, not proof that records belong to one campaign.

Evidence is incomplete. Sample flows lack payload, authentication outcomes, asset importance and business context. Connection counts cannot prove password guessing, and packet volume cannot prove service failure. Source pointers support traceability but do not independently validate the original captures or labels. Timestamp timezone assumptions must not be strengthened beyond the source data.

AI validation is necessary but limited. A final review found two stored results incorrectly asserting that linked alerts exceeded the case window. The case-details tool had omitted the grouped end time. It now exposes both bounds and distinguishes the detection bucket from case duration. New and stored proposals are checked for explicit contradictory time claims; blocked results cannot support assessment confirmation or recommendation approval. Original audit records are retained. This bounded English check is not a general semantic verifier. Confidence is model-reported rather than empirically calibrated. External abstention may be appropriate caution, but it also leaves the analyst with unresolved work. Small purposive samples, no expert adjudication and an unpinned model prevent strong accuracy or reproducibility claims.

Human review is also unmeasured. A recorded name, approval click or written reason is not evidence of a sound security decision. The interface now explains assessment confirmation, step approval, completion and resolution separately, but its usability still needs testing with novice and experienced analysts. The prototype has not demonstrated reduced investigation time, lower workload or improved analyst outcomes.

The audit chain is locally verifiable, not tamper-proof against a machine or database administrator who can replace the storage and application. Static historical JSON is bundled with the frontend. The single-user loopback demo and its authentication are not a production data-isolation boundary. Model-provider use also requires an appropriate evidence-sharing policy.

6 6 Next evaluation priorities

Future detector work should separate training, calibration and fresh test traffic before threshold selection. The experimental Isolation Forest baseline is not deployed and was not retrained in this revision. Recall tuning is deferred, and the frozen external result remains unchanged.

Future AI evaluation needs larger external samples, expert review, a pinned model and separate error and abstention measurements. Authentication and service-health evidence are needed for stronger conclusions. A user study must measure investigation time and decision quality.

Conclusion

RiskPilot AI demonstrates a functioning SOC investigation workflow with traceable evidence, read-only AI tools, analyst control and auditable decisions. The acceptance results support those implementation claims. They also show that robust cross-domain detection and useful AI classification remain unproven. The prototype is suitable for demonstrating controlled investigation, with these limitations stated openly.

7 Operating the Prototype

7 1 From a case to an accountable record

Where	Analyst action	Recorded effect
Investigations	Open a case by review priority.	Activity-based order with reasons, independent of the AI verdict.
Overview	Read the signal and run AI investigation.	Read-only tool trace, findings, citations and model-reported confidence.
Timeline	Expand a flagged minute and inspect evidence.	Shows record IDs, rule criteria and source-linked traffic.
Overview	Confirm or reject the AI assessment.	Records the analyst judgment about that assessment.
Recommendations	Choose steps and save decisions.	Adds approved work to Home and creates a case-note draft.
Home	Perform the investigation and mark it done.	Records completion separately from approval.
Case record	Save the summary; optionally print to PDF.	Appends a summary snapshot without closing the case.
Case record	Resolve only when justified.	Explicit confirmation and a written reason remove it from the active queue.

7 2 Priority and uncertainty

Review priority is an explainable activity heuristic. It combines case-average flow rate, related alert count, actual alert-source diversity and the maximum destination-port count. Scores of 5 or more are High, 3 to 4 are Medium and 0 to 2 are Low; invalid inputs are Not assessed. These levels order review work. Low does not mean safe, and the score is not a calibrated security risk or attack probability. An analyst may override it with a reason; the change is appended to the audit log.

A new composite risk score, inferred attack stage and automatic historical-case influence were deliberately not added. The available flow evidence does not establish asset impact or a multi-stage campaign. Adding unsupported factors would make the queue harder to explain. IRIS offers useful patterns for evidence and case operations; Argus illustrates agent traces and proposed actions, but neither project validates this prototype or guarantees competition points [9, 10].

8 Competition Alignment

The official brief was checked on 24 October 2026. It asks for a focused working prototype, not a particular recall threshold or a mandatory task-list design. The following mapping concerns implemented evidence, not a claim of winning or official acceptance [1].

Brief area	Implementation and acceptance evidence
Problem and user	Tier 1 and Tier 2 case triage, with evidence-linked investigation rather than automatic dismissal.
Inputs and evidence	Historical CIC flows; 9 grouped cases; source IDs and minute drill-down; dataset labels withheld from AI.
Agent workflow	Four bounded read-only tools, model-selected queries, citations, confidence and a visible trace.
Defensive action	A review-prioritised incident and a proposed investigation plan, not autonomous containment.
Human approval	Authenticated assessment review and step decisions; explicit manual case resolution.
Results and limitations	Regression and safety checks, historical development and external measurements, poor recall and AI abstention disclosed.

8 1 Final verification boundary

Local reconstruction confirms 9 cases, 158 alerts, 948 flow samples and 1,106 evidence-linked timeline events. The synthetic safety evaluation passes 21 scenarios. The frontend builds successfully. Read-time revalidation withholds the two known contradictory stored results without rewriting their history. Regression checks cover new and saved results, evidence fingerprints, citations and approval refusal. A native browser walkthrough exercised evidence inspection, step approval, draft creation and record saving with an explicitly labelled offline fixture and isolated test identity. It is a UI check, not a live AI result.

The final isolated Codex replay for INC-A787E11F2A22 completed in 54.89 seconds: four read-only tool calls, four cited records and two proposed steps. It returned Needs Review with medium confidence and no validation issues or unsupported window-conflict claim. A simulated analyst confirmed the assessment, approved one step, generated a DRAFT case note and saved the record. The persisted ten-event audit chain verifies successfully. Formal state was unchanged. This single development case verifies the workflow, not AI accuracy or human judgment quality. Results are recorded in final-live-workflow-20261024.json.

8 2 Deliberate exclusions

Detector recall tuning, production deployment, live containment, attack-stage scoring and slide production are outside this revision. The frozen low-recall external result is retained unchanged. A complete workflow can demonstrate value while still requiring honest disclosure of detector and model limitations.

References

[1] HackAI. (2026). Agentic Cyber Defence challenge brief. GDEX x ANON x UTAR Agentic AI Cybersecurity Hackathon. https://hackai.my/tracks/cyber-defence

[2] Alahmadi, B. A., Axon, L., & Martinovic, I. (2022). 99% false positives: A qualitative study of SOC analysts' perspectives on security alarms. 31st USENIX Security Symposium, 2783-2800. https://www.usenix.org/conference/usenixsecurity22/presentation/alahmadi

[3] Canadian Institute for Cybersecurity. (n.d.). Intrusion detection evaluation dataset CIC-IDS2017. University of New Brunswick. https://www.unb.ca/cic/datasets/ids-2017.html

[4] Hochschule Coburg. (n.d.). CIDDS Coburg Intrusion Detection Data Sets. https://www.hs-coburg.de/forschen/cidds-coburg-intrusion-detection-data-sets/

[5] MITRE. (2026). Network Service Discovery T1046. MITRE ATT&CK. https://attack.mitre.org/techniques/T1046/

[6] MITRE. (2026). Brute Force T1110. MITRE ATT&CK. https://attack.mitre.org/techniques/T1110/

[7] MITRE. (2025). Network Denial of Service T1498. MITRE ATT&CK. https://attack.mitre.org/techniques/T1498/

[8] OWASP. (2025). LLM06 Excessive Agency. OWASP Gen AI Security Project. https://genai.owasp.org/llmrisk/llm062025-excessive-agency/

[9] DFIR-IRIS. (n.d.). Alerts operations documentation. https://docs.dfir-iris.org/latest/operations/alerts/

[10] Pavilion-devs. (n.d.). Argus repository. https://github.com/Pavilion-devs/argus

Web references checked on 24 October 2026. Numerical results in this report are project measurements, not findings attributed to these external sources.

Project Evidence

The latest acceptance record is FINAL_ACCEPTANCE.md; JOINT_ACCEPTANCE.md preserves the earlier evaluation history. The following files under evaluation/ provide the underlying measurements and hashes.

Detection: detection-joint-20261024.json and cidds-joint-20261024.json.

Grouping and timeline: grouping-development-20261023.json and joint-contracts-20261024.json.

Live AI: live-joint-acceptance-20261024.json; cidds-ai-diagnostic-20261024/manifest.json and results.json.

Final live workflow: final-live-workflow-20261024.json, with a persisted isolated review audit and draft.

Latest contracts: final-contracts-20261024.json and final-safety-20261024.json. Test count: data/final-workflow-tests.xml.